

Operating System Security - TryHackMe

Objectif

Comprendre les bases de la sécurité des systèmes d'exploitation (Triade CIA) et compromettre un serveur Linux distant. L'objectif final est de réaliser une escalade de privilèges (Privilege Escalation) pour obtenir l'accès "root".

Reconnaissance

Avant de lancer mon terminal, j'ai identifié le vecteur d'attaque initial : un mot de passe fuité via un post-it (**dragon**) appartenant à l'utilisateur **sammie**. Je connais l'adresse IP de la machine cible et j'ai déterminé que le service SSH (Secure Shell) était actif. J'ai également identifié deux autres utilisateurs cibles potentiels : **johnny** et **linda**.

Exploitation / Résolution

1. **Accès Initial (Initial Access)** : J'ai utilisé le mot de passe compromis pour me connecter à distance au serveur via SSH : **ssh sammie@MACHINE_IP**
2. **Mouvement Latéral (Lateral Movement)** : Sachant que l'utilisateur **johnny** avait de mauvaises pratiques de sécurité, j'ai bruteforcé manuellement son compte depuis ma session **sammie** en me basant sur le Top 7 des pires mots de passe connus. J'ai basculé sur son compte avec la commande : **su johnny**
3. **Fouille et Escalade de Privilèges (Privilege Escalation)** : Une fois sur le compte de Johnny, j'ai fouillé ses traces avec la commande **history** pour lire l'historique de son terminal.
4. **Root** : Jackpot. L'historique a révélé que Johnny avait tapé le mot de passe du superutilisateur (root) par erreur dans le terminal. J'ai utilisé **su root**, entré le mot de passe volé dans l'historique, et pris le contrôle total de la machine.
5. J'ai extrait le flag final situé dans le répertoire root avec un simple **cat flag.txt**.

Résultat

✓ Compromission totale du serveur et accès **Root** obtenu. **Apprentissage** : La compromission d'un système ne vient pas toujours d'une faille technique complexe, mais souvent de l'erreur humaine : mots de passe faibles (dictionnaire), post-it compromis, et mots de passe tapés en clair dans l'historique bash. Une illustration parfaite des attaques contre la *Confidentialité* (triade CIA).

Outils utilisés

- Réseau / Remote Access : **ssh**

- **Post-Exploitation & Pivot** : `su` (Switch User)
- **Forensics / Recherche d'infos** : `history`, `cat`, `whoami`
- **Concepts de sécurité** : Triade CIA (Confidentiality, Integrity, Availability),
Moindre Privilège, Authentification.